

Secure Infrastructure

Device Placement:

Every network is different:

- There often similarities

Firewalls:

- Separate trusted from untrusted
- Provide additional security checks

Other services may require their own security technologies:

- Honeypots, Jump server, load balancers, sensors

Security zones:

Zone based security tech:

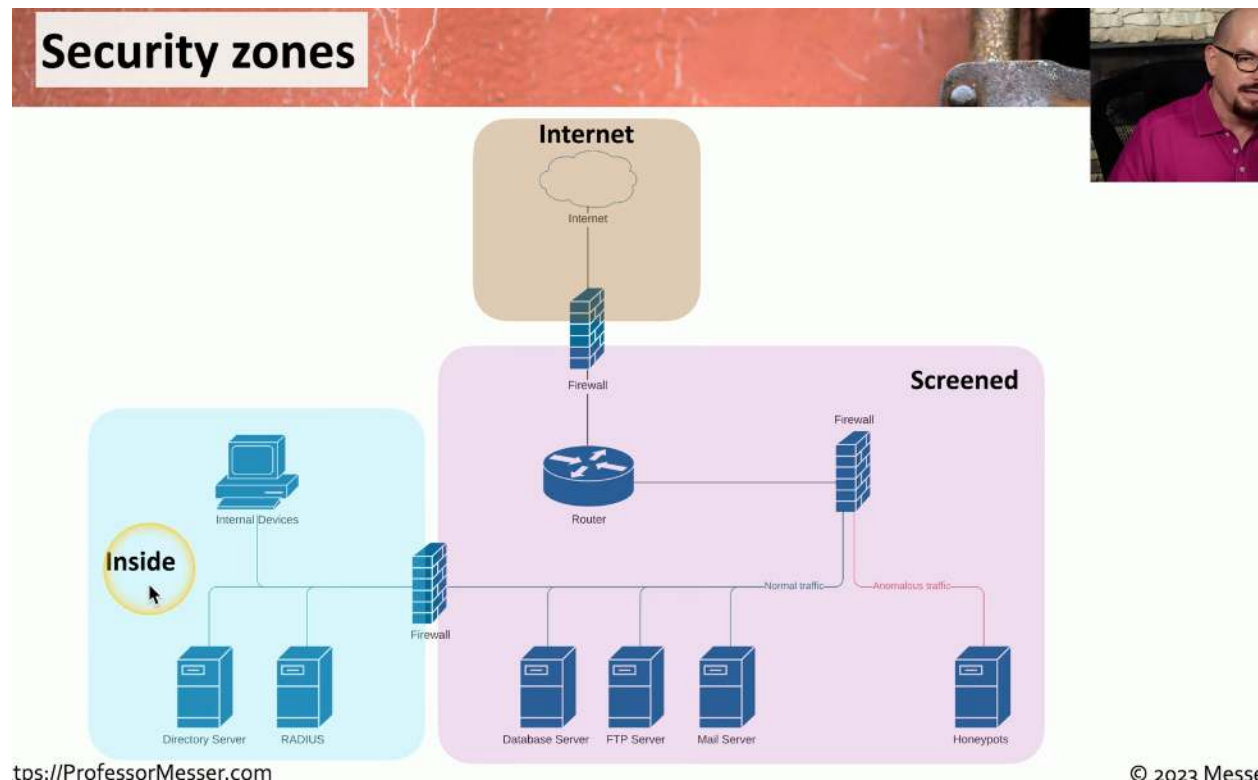
- For flexible (and secure) than IP address ranges

Each area of the network is associated with a zone:

- Trusted, untrusted
- Internal, external
- Inside, Internet, servers, databases, screened

This simplifies policies:

- Trusted to untrusted
- Untrusted to screened
- Untrusted to Trusted



Attack Surface:

How many ways to enter your home:

- Doors, windows, basement

Everything can be a vulnerability:

- App code
- Open ports
- Authentication process
- Human error

Minimize attack surface:

- Audit code
- Block ports on firewall
- Monitor network traffic

Connectivity

Everything contributes to security:

- Including the network connection

Secure network cabling:

- Protect the physical drops

Application-level encryption:

- The hard work has already been done

Network level encryption:

- IPsec tunnels, VPN connections

Intrusion Prevention

Intrusion Prevention System (IPS)

Intrusion Prevention System:

- Watches network traffic

Intrusions:

- Exploits against OS, Applications, etc.
- Buffer overflows, cross site scripting, and other vulnerabilities

Detection vs prevention:

- Intrusion Detection System (IDS) - Alarm or alert
- Prevention - stop it before it gets into the network

Failure modes:

We hope for 100% uptime:

- This obviously isn't realistic
- Eventually, something will break

Fail-open:

- When system fails, data continues to flow

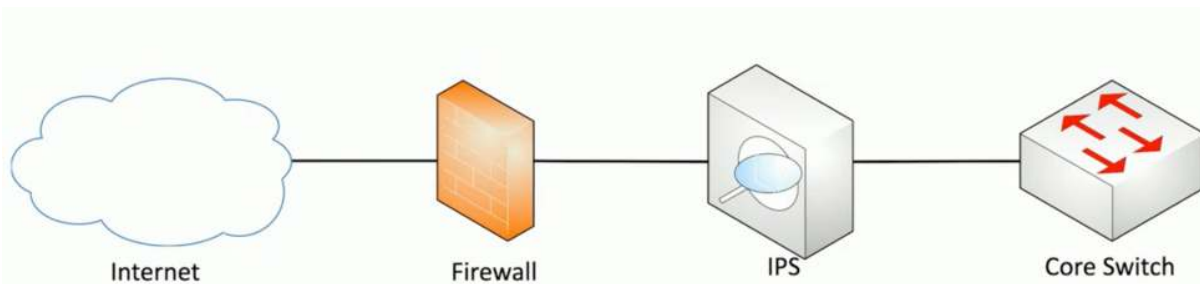
Fail closed:

- When a system fails data does not flow

Device connections:

Active Monitoring:

- System is connected inline
- Data can be blocked in real time as it passes by
- Intrusion prevention is commonly active



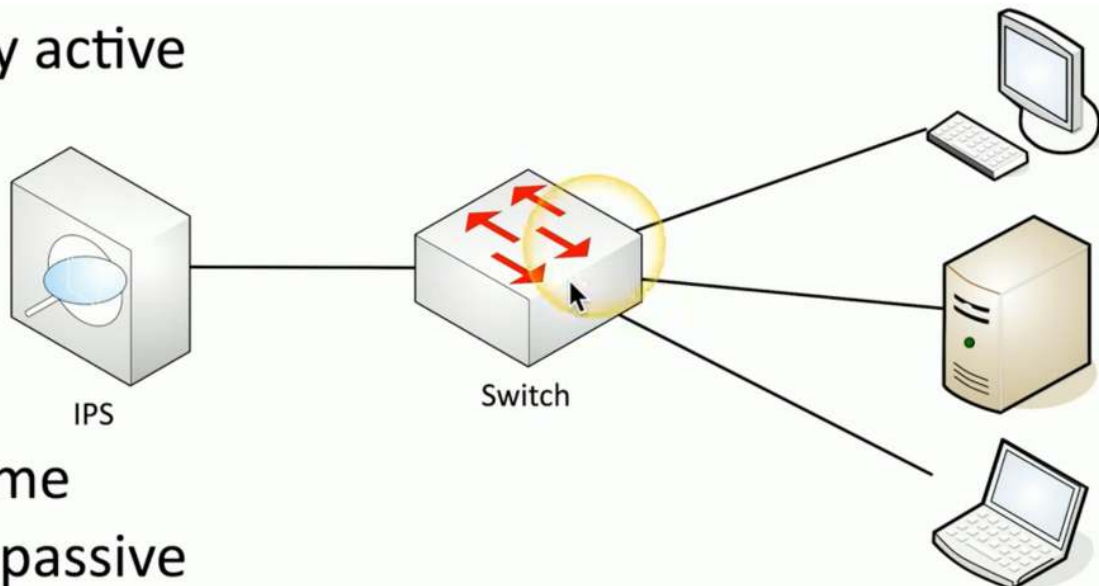
Passive Monitoring:

- A copy of the network traffic is examined using a tap or port mirror
- Data cannot be blocked in real time
- Intrusion detection is commonly passive

only active

time

y passive



The benefit of active monitoring is malicious traffic is spotted immediate and is kicked out of the network by the IPS.

Passive monitoring has no way of blocking traffic so its normally run with IDS to give an alarm bell passively saying HEY BAD CODE NEED ACTION.

Network Appliances

Jump server:

Access secure network zones:

- Provides an access mechanism to a protected network

Highly secured device:

- Hardened and monitored

SSH /Tunnel VPN to jump server:

- RDP, SSH, or jump from there

A significant security concern:

- Compromise of the jump server is na significant breach

Proxies:

Sits between the users and the external network

Receives the user requests and send the request on their behalf (the proxy)

Useful for caching information, access control, URL filtering, content scanning

Proxies are just middle men that adds a layer of security so bad URLS and content dont infect the network.

Apps may need to know how to use the proxy (explicit).

Some proxies are invisible (transparent)

Application proxies:

One of the simplest proxies is NAT:

- A network level proxy

Most proxies in use are app proxies:

- the proxy understand the way the app works

A proxy may only know one app:

- HTTP

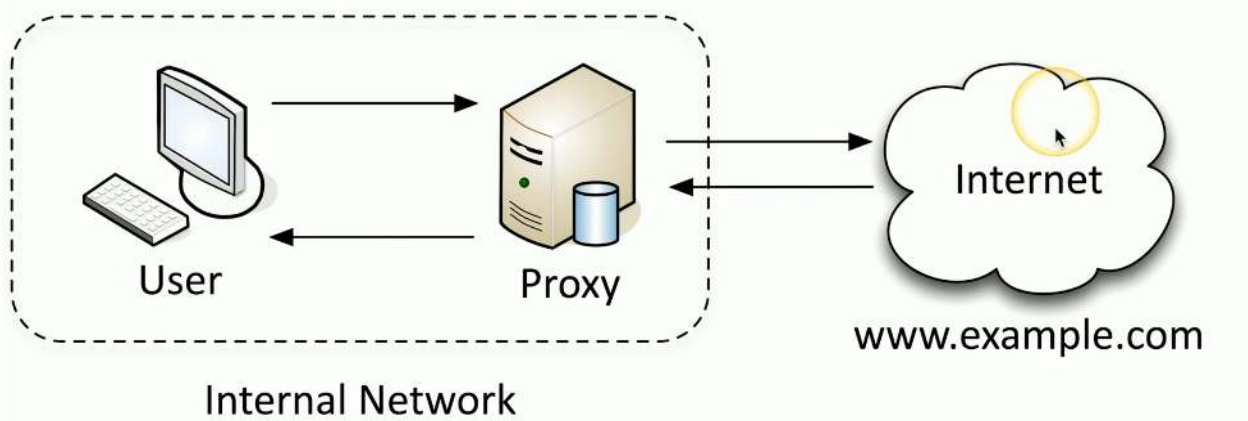
Many proxies are multipurpose proxies:

- HTTP, HTTPS, FTP, etc

Forward proxy:

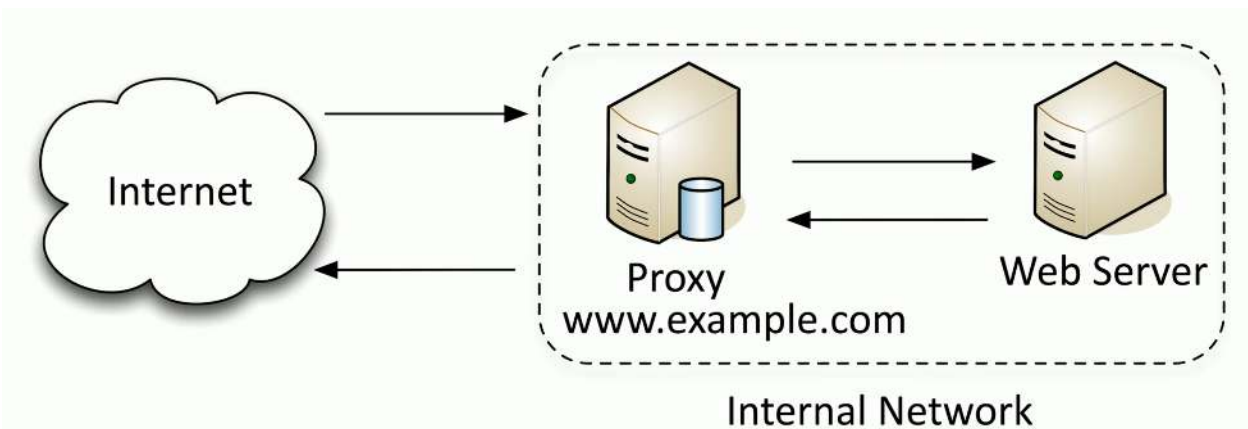
An “internal proxy” :

Commonly used to protect and control user access to the internet



Reverse proxy:

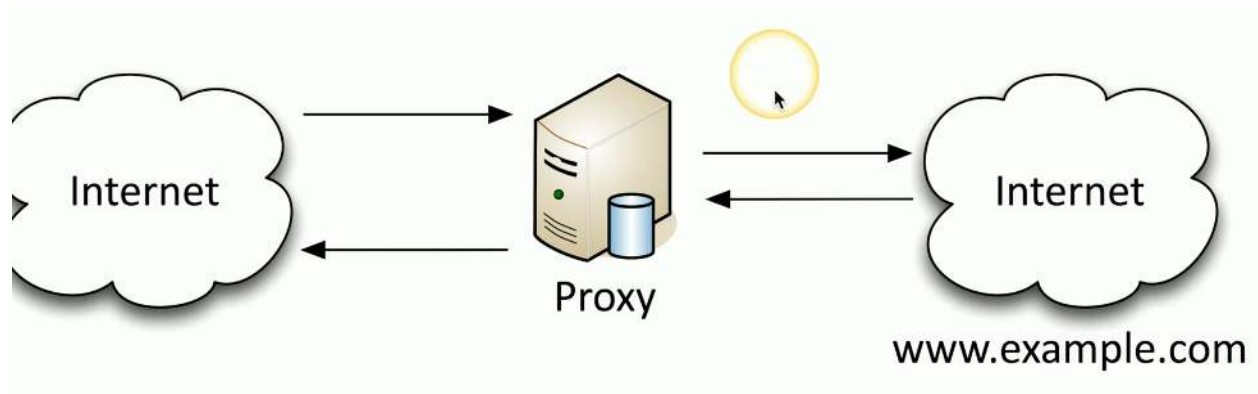
Inbound traffic from the internet to your internal service:



An Open Proxy:

A third part, uncontrolled proxy:

- Can be a significant security concern
- Often used to circumvent existing security controls



Open proxies = Dangerous

Balancing the load:

Distributed the load:

- Multiple servers
- Invisible to the end user

Large scale implementations:

- Web server farms, database farms

Fault tolerance:

- Server outages have no effect
- Very fast convergence

Active/Active load balancing:

Configurable load:

- Manage across servers

TCP offload:

- Protocol overhead

SSL offload:

- Encryption/Decryption

Caching:

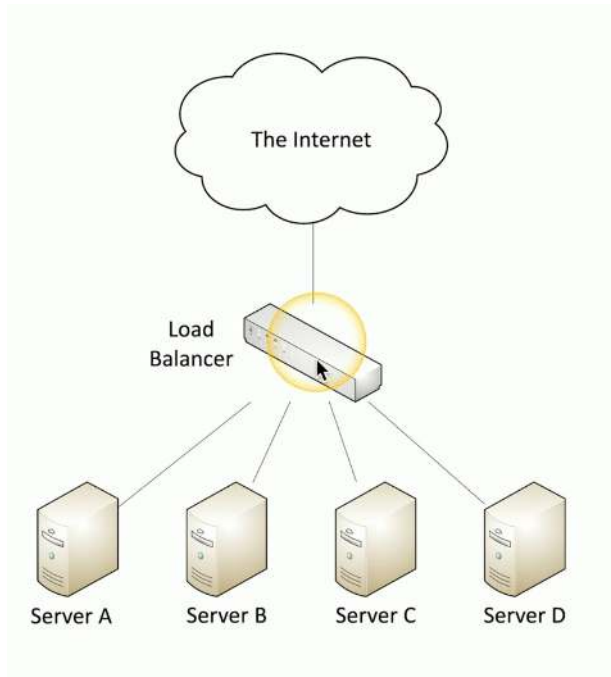
- Fast response

Prioritization:

- QOS

Content switching:

- App-centric balancing

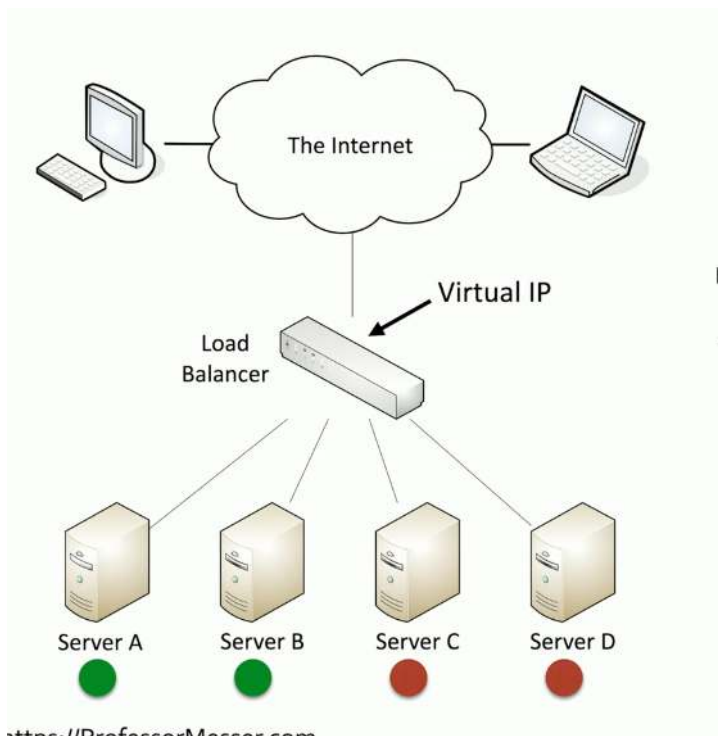


Active/passive load balancing:

Some servers are active:

- Others on standby

If an active server fails, the passive server takes its place



Sensors and Collectors:

Aggregate information from network devices:

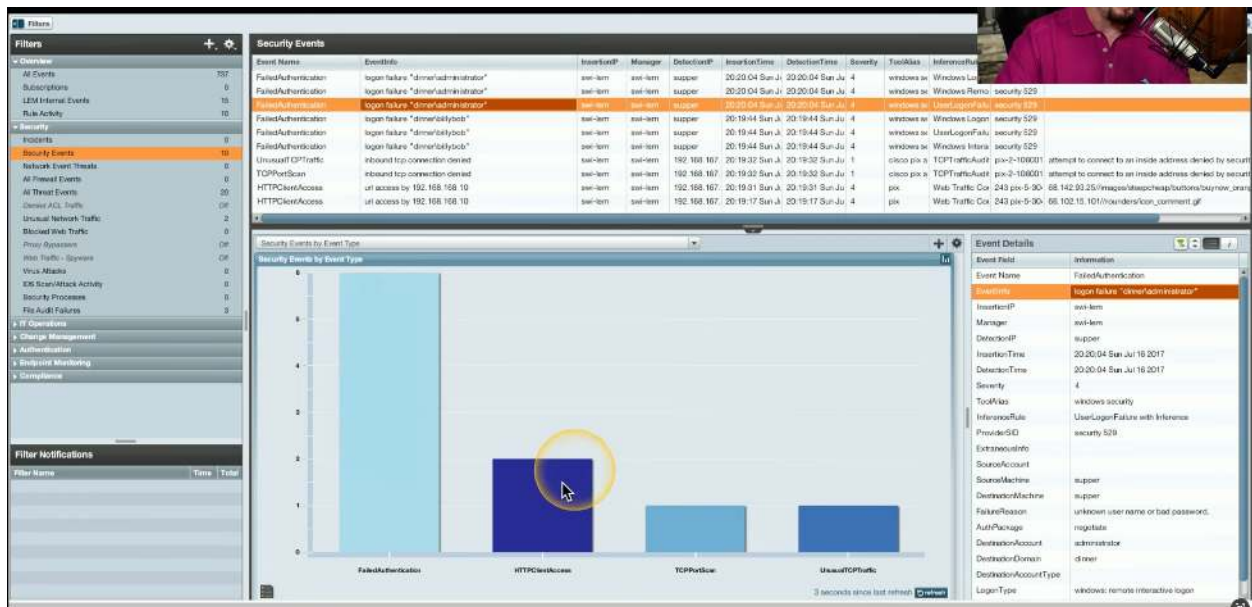
- Built in sensors, separate devices
- Integrated into switches, routers, servers, firewalls, etc.

Sensors:

- Intrusion prevention systems, firewall logs, authentication logs, web server access logs, database transaction logs, Email logs

Collectors:

- Proprietary consoles (IPS, Firewall), SIEM consoles, syslog servers
- Many SIEMs include a correlation engine to compare diverse sensor data



SIEM console

Port Security

We've created many authentication methods through the years;

- A network admin has many choices

Use a username and password:

- Other factors can be included

Commonly used on wireless networks:

- Also works on wired networks

EAP Extensible Authentication Protocol (EAP):

- An authentication framework

Many different ways to authenticate based on RFC standards:

- Manufacturers can build their own EAP methods

EAP integrates with 802.1X:

- Prevents access to the network until the authentication succeeds

IEEE 802.1X;

- Port based network access control (NAC)
- You don't get access to the network until you authenticate

EAP integrates with 802.1X:

- Extensible Authentication protocol:
- 802.1X prevents access to the network until authentication is successful

Used in conjunction with an authentication database:

- RADIUS, LDAP, TACACS+, Kerberos, etc.

Supplicant - the client

Authenticator - the device that provides access

Authentication server - Validates the client creds

Firewall Types

The universal security control

Standard issue:

- Home, office, OS etc.

Control the flow of network traffic:

- Everything passes through the firewall

Corporate control of outbound and inbound data:

- Sensitive materials

Control of inappropriate content:

- NSFW parental controls

Protection against evil:

- Anti-Virus, Anti-malware

Network based firewalls:

Filter traffic port by port number or application;

- OSI layer 4 versus OSI layer 7
- Traditional vs NGFW Firewalls

Encrypt traffic;

- VPN between sites

Most firewalls can be layer 3 devices (routers):

- Often sits on the ingress/ egress of the network
- Network address translation (NAT) functionality
- Authenticate dynamic routing communication

U

UTM / All in one security appliance:

Unified Threat Management (UTM) / Web security gateway

Capabilities:

- URL filter / Content inspection
- Malware inspection
- Spam filter
- CSU/DSU
- Router, switch
- Firewall
- IDS/IPS
- Bandwidth shaper
- VPN endpoint

Challenges:

- only operate at layer 4
- All the capabilities have a draw back in performance

Next generation firewall (NGFW):

The OSI Application layer:

- All data in every packet

Can be called different names:

- Application layer gateway
- Stateful multilayer inspection
- Deep packet inspection

Requires som advanced decodes:

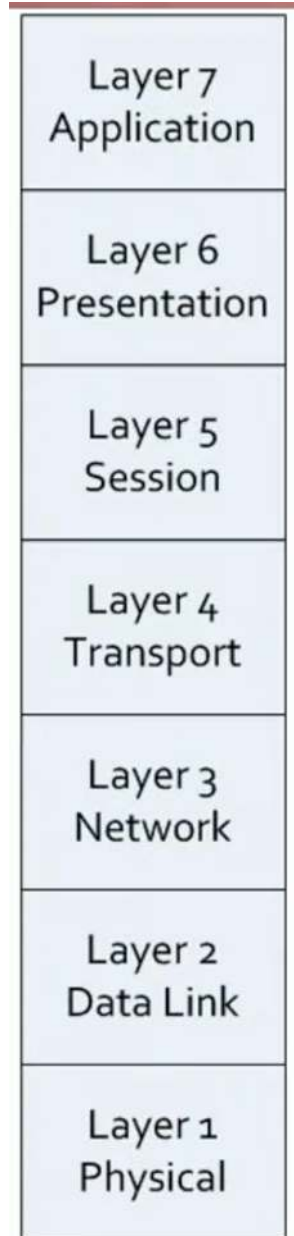
- Every packet must be analyzed and categorized before a security decision is determined

Network based firewalls:

- Control traffic flows based on the application
- Microsoft SQL Server, Twitter, YouTube. More custom Firewalls and restrictions

Intrusion prevention systems:

- Identify the application



- Apply application - specific vulnerability signatures to the traffic

Content filtering:

- URL filters
- Website filters

Web Application Firewall (WAF);

Not like a normal firewall:

- Applies rules to HTTP/HTTPS conversations

Allow or deny based on expected input:

- Unexpected input is common method of exploiting an application

SQL injection:

- Add your own commands to an applications SQL query

A major focus of Payment Card Industry Data Security Standard (PCI DSS)

Secure Communication

VPNs :

Virtual private networks:

- Encrypted (private) data traversing a public network

Concentrator:

- Encryption/decryption access device
- Often integrated into the firewall

Many deployment options:

- Specialized cryptographic hardware
- Software based options available

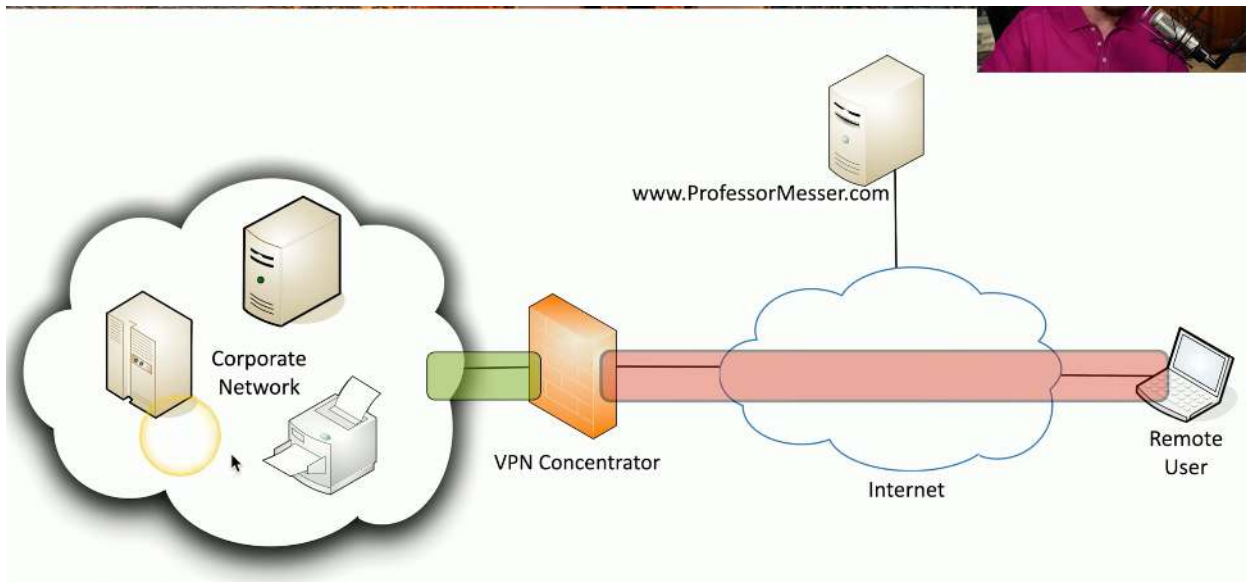
Used with client software

- Sometimes built into the OS

A third party, uncontrolled proxy:

- Can be a significant security concern
- Often used to circumvent security controls

Encrypted Tunnel example:

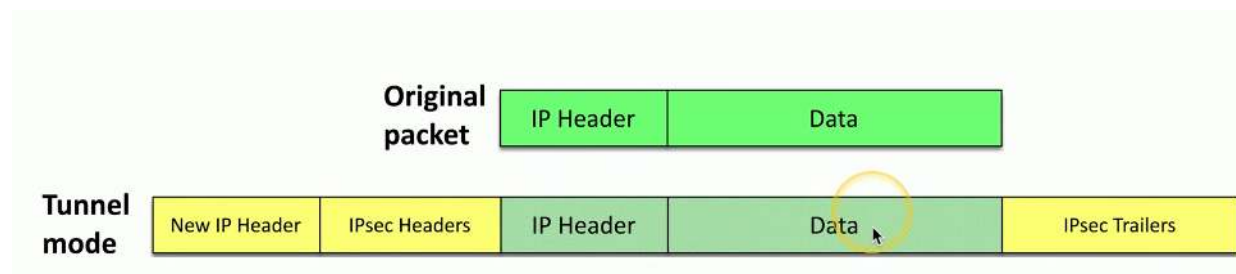


Keep data private across the public internet:

- Encryption is the key

Encrypt your data:

- Add new headers and trailers



Decrypt on the other side;

- Original data is delivered

SSL/TLS VPN (secure Sockets Layer VPN):

Uses common SSL/TLS protocol (tcp/443)

No big VPN clients:

- usually remote access communication

Authenticate users:

- No requirement for digital certificates or shared passwords (like IPsec)

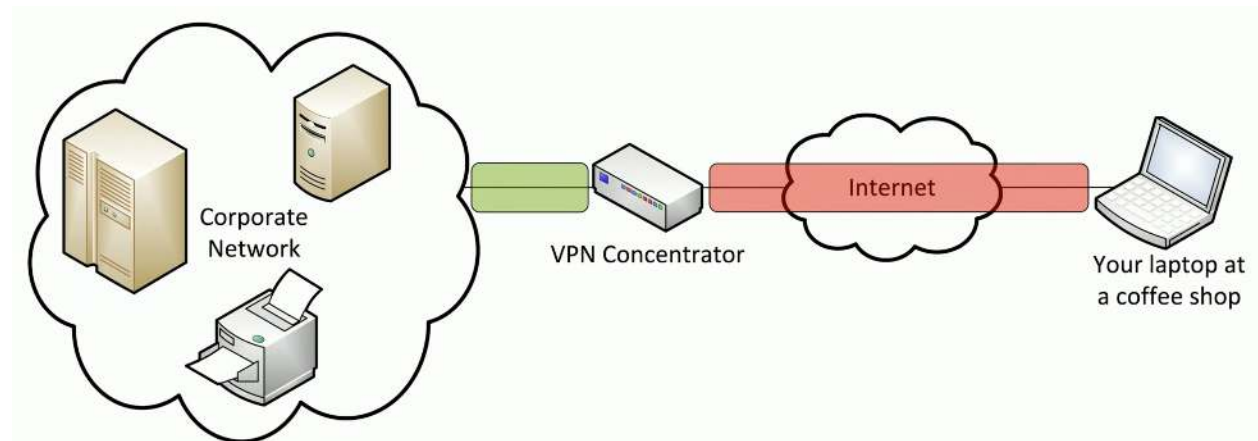
Can be run from a browser or from a (usually light) VPN client:

- Across many OS

SSL/TLS VPN

On demand access from a remote device:

- Software connects to a VPN concentrator
- Some software can be configured as always on



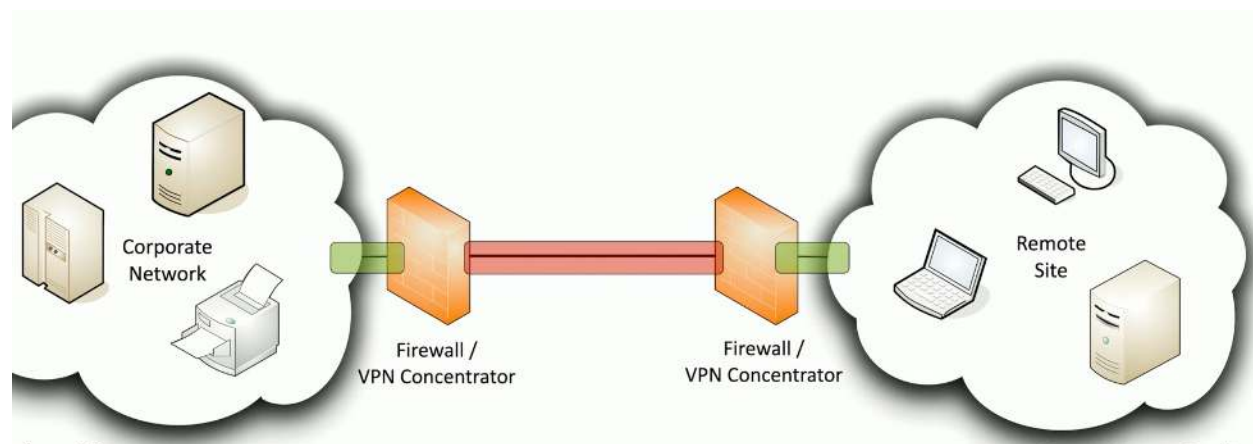
Site to site IPSec VPN:

Always-on:

- Or almost always

Firewalls often act as VPN concentrators:

- Probably already have firewalls in pack



SD-WAN

Software Defined Networking in a Wide Area Network:

- A WAN built for the cloud

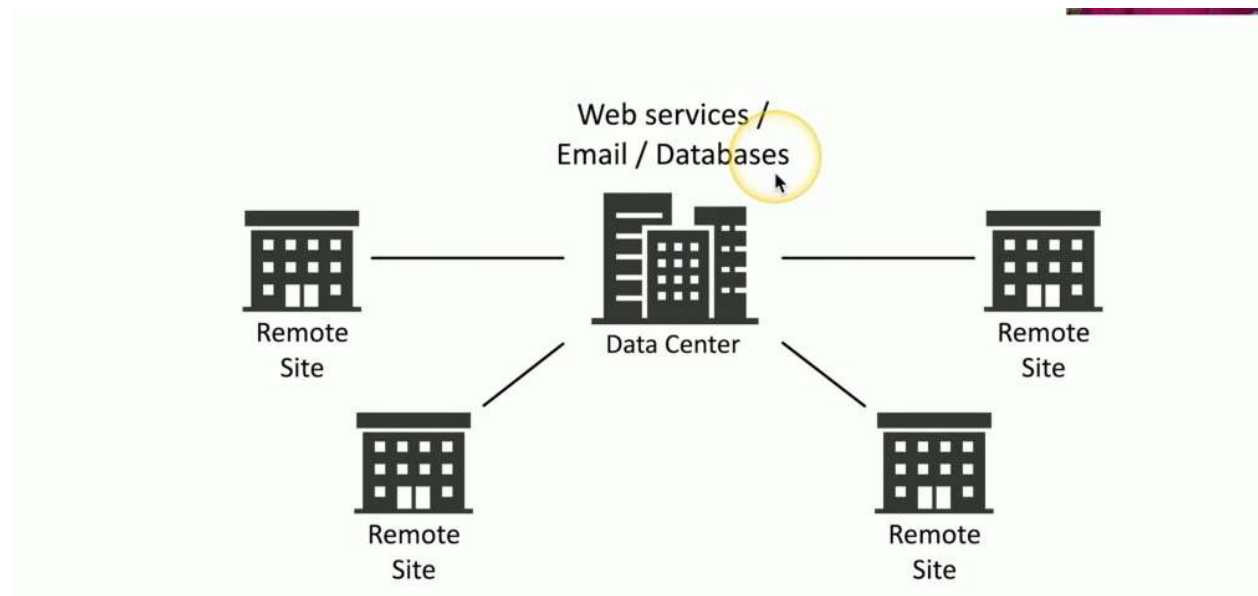
The data center used to be the one place:

- The cloud has changed everything

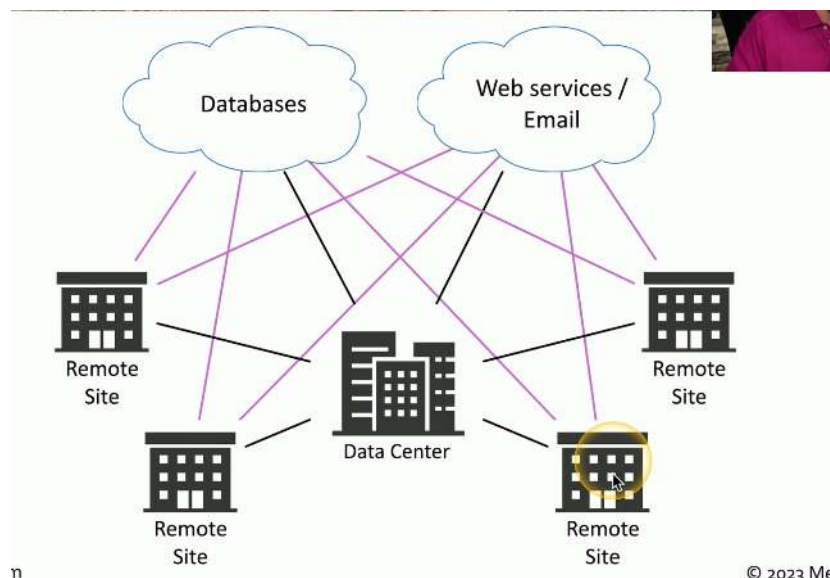
Cloud based applications communicate directly to the cloud:

- No need to hop through the central point

Traditional:



Now with Cloud:



Secure Access Service Edge (SASE)

Update secure access for cloud services:

- Securely connect from different locations

Secure Access Service Edge (SASE):

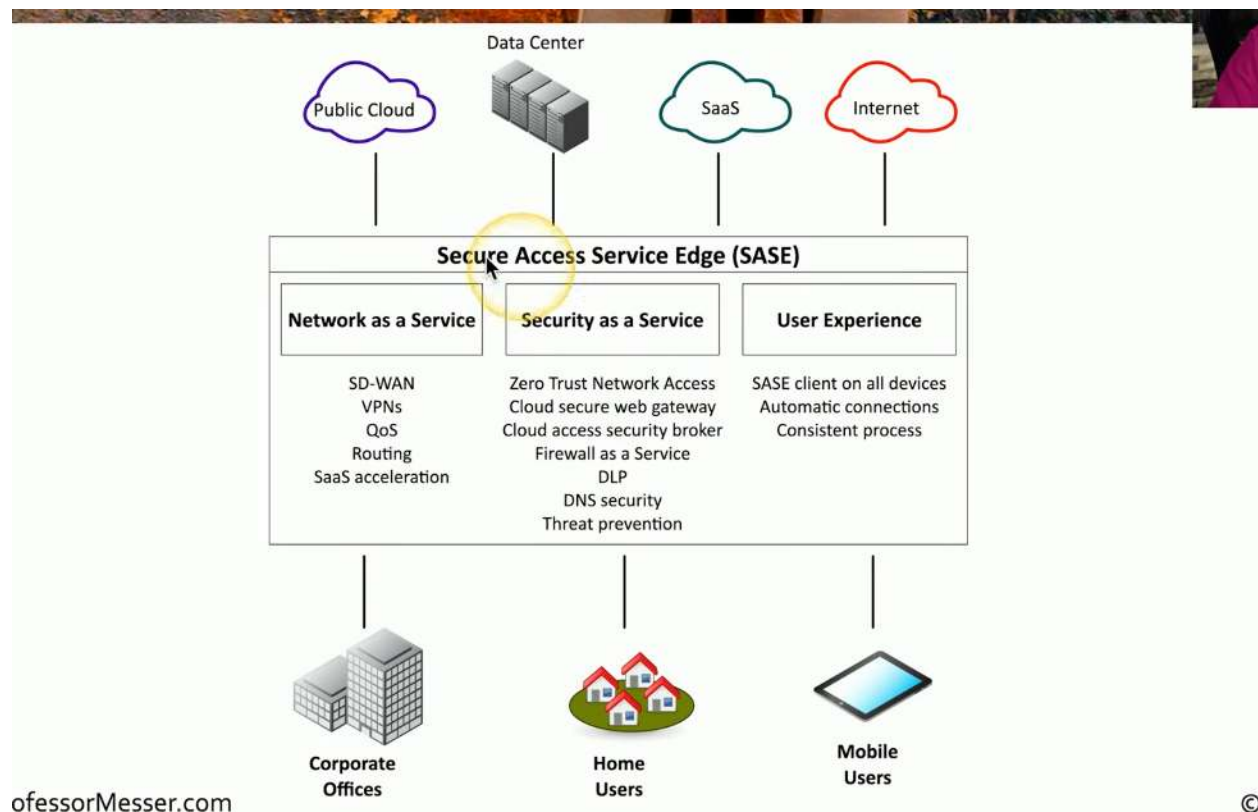
- A “next generation” VPN

Security technologies are in the cloud:

- Located close to existing cloud services

SASE clients on all devices:

- Streamlined and automatic



ofessorMesser.com

©

Selection of effective controls:

Many different security options:

- Selecting the right choice can be challenging

VPN:

- SLL/TLS VPN for user access
- IPSec tunnels for site to site access

SD WAN:

- Manage the network connectivity to the cloud
- Does not adequately address security options

SASE:

- A complete network and security solution
- Requires planning and implementation